



[Resource](#) > [Glossary](#) > [What Is Vulnerability Prioritization?](#)

What Is Vulnerability Prioritization?

LAST UPDATED: December 27, 2023

Table of Contents:

[What Is Vulnerability Prioritization?](#)

[The 5 Factors to Consider Prioritizing Vulnerabilities](#)

[What Are the Challenges of Prioritizing Vulnerabilities](#)

[A Critical CVSS Score Doesn't Always Indicate Critical Risk in Vulnerability Remediation Prioritization](#)

[How to Prioritize Vulnerability Remediation?](#)

[Vulnerability Prioritization Tools](#)

The Red Report 2024

[The Top 10 MITRE ATT&CK Techniques Used by Adversaries](#)

DOWNLOAD



By [Picus Labs](#) • September 18, 2023, 13 min read

In today's expanding threat landscape, organizations face complex IT environments with vulnerabilities even in IT giants' products, making it challenging to manage effective vulnerability remediation. Many organizations lack the resources, and with employees

already burdened, addressing these vulnerabilities becomes an added responsibility. Due to limited resources, dependencies on vulnerable software, and the vast number of vulnerabilities, it's impossible to address every one. Much like not all chess pieces have the same significance, organizations should prioritize vulnerabilities based on severity, exploitability, and business impact.

Hence, our dedicated red team engineers investigate vulnerabilities, mimicking the most commonly exploited ones while also considering their potential business-critical impact and real-world scenarios. These findings are incorporated into the **threat library** of the **Picus Complete Security Control Validation Platform**, enabling our customers to address their security gaps proactively before adversaries can capitalize on them. This approach provides not only patch validation but also mitigation suggestions

What Is Vulnerability Prioritization?

Vulnerability prioritization is the process of **identifying vulnerabilities and prioritizing their remediation** based on potential impact, exploitability, and other contextual factors such as asset information, severity, business-critical impact, and threat intelligence. The aim is to ensure that high-risk vulnerabilities are addressed first and lower-risk vulnerabilities are addressed subsequently, all within the context of an organization's specific goals and risk tolerance.

Figure 1. Vulnerability Prioritization with Chess Analogy [1]

The concept of vulnerability prioritization likens vulnerable organizational assets to pieces in a chess game, understanding that the loss of each piece doesn't carry the same weight. For example, in most scenarios, losing a pawn doesn't equate to the stress of losing a queen. Given this, organizations, with their limited human resources already burdened by daily tasks, don't chase every vulnerability but focus on those that require immediate remediation.

Benefits of Vulnerability Management Prioritization

Adopting a *vulnerability management prioritization promotes a proactive cybersecurity approach*, granting continuous visibility into an organization's assets, their associated exposures, and the severity of vulnerabilities anchored in their business impact. With this clarity, organizations can more effectively allocate their limited resources, targeting those vulnerabilities that demand urgent attention. This not only ensures that potential security breaches are addressed in a timely manner but also prevents skilful adversaries from exploiting them, thereby safeguarding both financial assets and the organization's reputation.

Furthermore, regulatory frameworks such as GDPR necessitate a vulnerability prioritization program. By adhering to these standards, organizations not only ensure compliance but also bolster their credibility by aligning with esteemed certifications.

The 5 Factors to Consider Prioritizing Vulnerabilities

When prioritizing vulnerability remediation, organizations need to consider a multifaceted approach to ensure they address the most pressing risks first. Here are the five key factors to consider, including *severity*, *exploitability*, *impact*, *asset information/value* and *threat intelligence*.

• Severity

This is often determined using tools like the [Common Vulnerability Scoring System \(CVSS\)](#). CVSS provides a standardized way to assess and rate the severity of vulnerabilities, giving a score between 0 to 10, with higher scores indicating higher severity.

CVSS v2.0 Ratings		CVSS v3.0 Ratings	
Severity	Base Score Range	Severity	Base Score Range
		None	0.0
Low	0.0-3.9	Low	0.1-3.9
Medium	4.0-6.9	Medium	4.0-6.9
High	7.0-10.0	High	7.0-8.9
		Critical	9.0-10.0

Figure 2. CVSS v.2.0 and v3.0 [Ratings](#)

The severity level indicates the potential impact a vulnerability can have on a system or application if exploited.

• Exploitability

This refers to how easily and likely a vulnerability can be exploited by potential attackers. Factors affecting exploitability include the availability of ***Proof of Concept (PoC)*** exploit code, the complexity required to exploit the vulnerability, and the potential rewards an attacker might get from the exploitation. Vulnerabilities with known exploits available publicly should be given higher priority.

Here is an example of how exploitability of a certain vulnerability affects its possible impact.

Discovered in April 2014, the ***Heartbleed vulnerability*** was a significant security flaw in the OpenSSL cryptographic library, impacting millions of websites and servers [1]. This flaw permitted attackers to access server memory using OpenSSL, exposing sensitive data like passwords, credit card details, and private keys.

Amplifying its risk, ***there was publicly available PoC exploit code***, allowing even those without special privileges to easily extract information from vulnerable servers. This breach led to extensive compromises, including data theft from government entities and financial institutions. Though OpenSSL released a patch in April 2014, ***many entities lagged in system updates***, prolonging the exploitation window. Heartbleed underscored the criticality of timely software updates and staying abreast of prevailing security threats.

• Impact

This assesses the potential consequences if a vulnerability is exploited. Potential impacts include data breaches, system downtimes, reputational damage, financial loss, and more. Understanding the ramifications can help organizations prioritize which vulnerabilities need immediate attention based on their potential harm.

• Asset Information/Value

Not all assets in an organization have the same value. Assets might include databases with sensitive information, critical infrastructure, or services vital for business operations. By understanding the importance and value of each asset, organizations can determine the potential business impact of a vulnerability and prioritize remediation efforts accordingly.

- **Threat Intelligence**

Incorporating real-world threat data helps organizations identify vulnerabilities that are currently being exploited in the wild or are part of trending attack patterns. Information about active exploits, recent attacks, and threats from credible sources can offer insights into which vulnerabilities are most likely to be targeted next.

In addition to these five key factors, the broader business context, regulatory compliance requirements, and the organization's specific risk appetite should also be considered in the vulnerability prioritization process. This holistic approach ensures that the prioritization aligns with the organization's business goals and risk management strategy.

What Are the Challenges of Prioritizing Vulnerabilities

The challenges that organizations face when it comes to vulnerability prioritization may be gathered under three main categories. Each of these categories are provided with a brief description.

- **Achieving Comprehensive Visibility into Organizational Assets**

especially when considering third-party tools and software dependencies. Even if you attain some clarity on these digital assets, understanding their vulnerabilities is another hurdle. It's essential to grasp their potential exposures, the likelihood of exploitation, the existence of publicly available proof-of-concepts for exploiting certain vulnerabilities, and the potential business impact.

Without the right tools, understanding both visibility and the criticality of these assets to the business becomes elusive.

- **Sheer Volume of Emerging Vulnerabilities and Lack of Vulnerability Patching Programs**

Figure 3. The Vulnerability Problem by X-Force Threat Intelligence Index 2023 [2].

Moreover, the sheer volume of emerging vulnerabilities, some of which even impact IT and security behemoths, further complicates matters. While affected security products diligently strive to address these vulnerabilities, organizations often find it challenging to keep up. Many systems and assets rely on older versions, which makes regular security updates tricky. At times, security patches don't function as intended. Crafty adversaries, in such instances, reverse engineer these patches, rendering the security upgrade ineffective by reverting to the previous vulnerability.

This lag in addressing vulnerabilities is evident in statistics. For instance, small companies typically take around 149 days to patch Windows 10 endpoints, with larger enterprises lagging slightly behind at 158 days. The CISA joint advisory [AA23-215A](#) from 2022 further emphasized the issue. It revealed that most routinely exploited vulnerabilities were old and had patches readily available. This is a stark reminder of how many organizations persistently operate on outdated, unpatched systems. Adversaries exploit these vulnerabilities using publicly available proof-of-concepts, some even found on platforms like YouTube.

• Collaboration between Other Teams for Addressing and Remediation of Vulnerabilities

Another layer to the challenge is the need for collaboration. Effective vulnerability remediation demands synchronized efforts from various stakeholders. This includes engineering and development teams, organizational executive teams who provide insights into the overall security posture, and security teams responsible for validating whether a patch works as intended.

A Critical CVSS Score Doesn't Always Indicate Critical Risk in Vulnerability Remediation Prioritization

A CVSS score quantifies a vulnerability's severity through standardized metrics, taking into account factors like the complexity of exploitation and potential impacts on data confidentiality, integrity, and availability. At first glance, a high CVSS score implies severe threats, warranting urgent attention.

However, while the [data from X-Force](#) shows that since 1988, **38% of tracked vulnerabilities rank as high and only 1% achieve a critical score of 10**, it's vital to understand that a **high CVSS score doesn't automatically translate to a significant risk for all organizations**.

For context, 4.0-6.9 out of 10 is considered medium, accounting for half of the tracked vulnerabilities, while 7.0-9.9 is deemed high. Interestingly, the prevalence of high severity vulnerabilities surpassed medium ones in 2021 by five percentage points.

Figure 4. CVSS Scores of Vulnerabilities in X-Force Database

That said, **a vulnerability with a top-tier CVSS score might exist in an organization's non-critical software module or might not even be active**. Furthermore, some high-scoring vulnerabilities *might demand specific conditions for exploitation*, absent in an organization's infrastructure. Additionally, the mere presence of a CVSS score doesn't directly correlate with the real-world threat of a vulnerability, since it doesn't account for how exploitation occurs or if an exploit even exists.

These scores are, however, instrumental for defenders to weigh vulnerabilities and determine their response urgency. But it's imperative to **recognize that a critical vulnerability does not always imply a business-critical risk**. The data underscores that

high CVSS score vulnerabilities are, in fact, exploited more often than critical ones.

How to Prioritize Vulnerability Remediation?

Prioritizing vulnerabilities is crucial to ensure that organizations address the most pressing security threats. Organizations can prioritize the vulnerability remediation in six main steps.

- **Step 1: Asset Visibility**

The foundation of any vulnerability prioritization program is having comprehensive visibility over assets in the organizational network and environment, including dependencies and third-party software and hardware.

Example Patching Scenario

Let's take a hypothetical company, *TechAInc*.

TechAInc decides to run a prioritizing vulnerability remediation program. Their first step is to conduct an *internal audit to enumerate all of their organizational assets*. This includes everything from servers, networking equipment, workstations, and software platforms. During this audit, *they identify several instances of Microsoft Exchange servers running within their infrastructure*.

- **Step 2: Comprehensive Attack Vector Coverage**

Once assets are identified, it's essential to understand the attack vectors that adversaries might exploit to gain an initial foothold in the organizational environment through vulnerable assets.

Scenario Continues

Upon reviewing the asset list, TechAInc performs an attack vector analysis. In light of recent vulnerabilities identified in Microsoft Exchange servers, particularly ProxyNotShell, TechAInc's IT team places special emphasis on these servers for a thorough attack vector assessment. Their analysis reveals that certain versions of their Exchange servers might be susceptible to the ProxyNotShell vulnerability chain.

How Does Picus Complete Security Validation Platform Help You with this Step?

Identifying the security gaps and potential attack vectors that adversaries can exploit to gain a foothold in your organization is a critical practice. For this purpose, the Picus Complete Security Validation platform provides a comprehensive and continuously updated threat library. Including various attack categories like malicious code, web application, and lateral movement techniques, the library also offers attack simulations that safely emulate the behaviors of tactics, techniques, and procedures (TTPs) seen in real-world exploitation attacks.

Figure 5. Picus Complete Security Validation Platform Threat Library

Additionally, the platform offers ready-to-run attack templates on vulnerabilities that are consistently targeted each year. This enables organizations to pinpoint outdated, overlooked, and unpatched software, prompting immediate remediation steps.

Figure 6. Ready-to-Run Threat Templates for Vulnerability Exploitation Attack Simulations

- **Step 3: Remediation Recommendations**

After identifying potential attack vectors, create actionable remediation steps to address these vulnerabilities.

Scenario Continues

The IT team at TechAInc, having identified potential vulnerabilities in their Exchange servers, *begins to draft remediation steps.*

They take note of Microsoft's update released on November 8, 2022, which patches the ProxyNotShell vulnerabilities. They

recommend an immediate patching program for these servers, along with ongoing monitoring for any signs of malicious activity.

How Does Picus Complete Security Validation Platform Help You with this Step?

Upon running an attack simulation using the Picus Complete Security Validation platform, if certain attacks bypass an organization's existing security measures, the platform promptly offers vendor-specific mitigation recommendations. These suggestions can be applied to affected preventative security controls such as Next-Generation Firewalls, Web Application Firewalls, EDR, XDR, and the like.

Figure 7. Vendor-based Mitigation Suggestions by Picus Complete Security Validation Platform.

- **Step 4: Business Context**

Vulnerabilities should also be assessed within the context of the business. Which assets are most critical to the organization's operations? Which vulnerabilities could potentially disrupt or damage the business's functionality?

Scenario Continues

TechAlnc evaluates their Exchange servers in the context of business operations. They determine that email communications are vital for their day-to-day operations, making the servers business-critical assets. Any prolonged downtime or breach could lead to financial losses and reputational damage. With this in mind, they prioritize the patching of their Exchange servers above other less-critical systems.

- **Step 5: Remediation Implementation**

Once the vulnerabilities have been prioritized based on the business context, organizations should implement the remediation steps.

Scenario Continues

Acting on the recommendations, TechAlnc promptly initiates the patching process for their Exchange servers. They also launch a communication campaign to inform their employees of the ongoing maintenance and potential email downtimes. After successful patch implementation, TechAlnc conducts a post-implementation review to ensure the vulnerabilities have been effectively addressed and no issues arise from the patching process.

- **Step 6: Validation of the Patches and Continuous Monitoring**

At the final step, even though the remediation steps are concluded, organizations need to verify if the applied patches and security updates are genuinely defending against exploitation attacks for particular and identified vulnerabilities. Moreover, even if the patches are functioning at the specific time the validation is conducted, adversaries might work around these patches using reverse engineering techniques. Hence, organizations need to implement corresponding rules that will trigger their SIEM product, alerting them to the adversaries' malicious behavior.

How Does Picus Complete Security Validation Platform Help You with this Step?

Security validation must be an ongoing practice. Given that simulations retain validity only for the brief period during which they're conducted, the Picus Complete Security Validation Platform assists customers in consistently performing attack simulations. This continuous approach helps gauge how effectively the current security controls shield the organization from potential attacks.

Moreover, recognizing that threats typically involve sequences of attack actions, the Picus platform offers detection rules suitable for integration into SIEM platforms, including Splunk, IBM QRadar, VMware Carbon Black EDR, Microfocus ArcSight ESM, and also incorporates Sigma rules.

Figure 8. Detection Content Library by Picus Complete Security Validation Platform.

By following this structured approach, TechInc managed to identify, prioritize, and remediate vulnerabilities in their critical business assets, ensuring the continuity of their operations and safeguarding their organizational reputation.

Vulnerability Prioritization Tools

Here are five open-source vulnerability prioritization tools.

- **OpenVAS (Greenbone Vulnerability Management):** Originally a fork of the Nessus project, OpenVAS has grown into a full-fledged vulnerability scanner and vulnerability prioritization tool that provides detailed insights into potential threats in systems.
- **VulnWhisperer:** This tool is designed to pull vulnerability data from various sources into a centralized location for analysis and prioritization, facilitating effective vulnerability management.
- **Vuls:** A go-based vulnerability scanner tailored for continuous scanning, Vuls is designed to prioritize vulnerabilities in a proactive manner, giving insights into potential threats.

- **CVE Search:** This web-based tool allows organizations to pull up-to-date vulnerability information directly from the National Vulnerability Database (NVD) and other sources, which can be useful for vulnerability prioritization.
- **Magellan:** An open-source tool that focuses on the storage aspect of vulnerabilities, Magellan can be used in tandem with other tools to prioritize vulnerabilities based on their potential impact.

By utilizing these vulnerability prioritization tools, organizations can more effectively assess, rank, and address potential vulnerabilities in their digital infrastructure.

Frequently Asked Questions (FAQs)

Here are the most frequently used questions regarding vulnerability prioritization.

What is Vulnerability Prioritization?

Vulnerability prioritization is the process of identifying vulnerabilities and prioritizing their remediation based on potential impact, exploitability, and other contextual factors such as asset information, severity, business-critical impact, and threat intelligence.

References

Please click here to see the references

DISCOVER MORE RESOURCES

Email*

Email

SUBSCRIBE NOW

REQUEST A DEMO

Platform

Use Cases

The Security Validation Platform
Security Control Validation
Attack Surface Validation
Cloud Security Validation
Attack Path Validation
Detection Rule Validation
Integrations

Breach and Attack Simulation
Pen Testing Automation
Continuous Threat Exposure Management

Resources

Blog
Purple Academy
Webinars
Reports
Case Studies
Press Releases
Datasheets
Cyberpedia
Events

Company

About Us
Careers
Contact
Customer Support
Trust Center

Subscribe to Our Newsletter

Contact Us

info@picussecurity.com
Schedule a meeting